

№	Пункт чек-листа (Позитивное требование)	Ссылка на угрозу (№ из отчета)	Ссылка на стандарт безопасности
1	Конфиденциальность учетных данных: Приложение не должно хранить учетные данные (логины/пароли) БД в открытом виде в файлах <code>.env</code> , <code>docker-compose.yml</code> или исходном коде. Должно быть обеспечено их безопасное хранение (например, через менеджеры секретов или Docker Secrets) и ротация.	№1 (9.4/10)	CWE-798: Use of Hard-coded Credentials
2	Минимизация привилегий в контейнере: Контейнер приложения (пользователь <code>app</code>) должен запускаться от непривилегированного пользователя (<code>non-root</code>), а не от <code>root</code> , для ограничения возможностей при компрометации.	№2 (8.4/10)	OWASP ASVS: V1.4.5 (Principle of least privilege)
3	Аудит действий пользователей: Приложение должно обеспечивать привязку критических операций (<code>INSERT</code> , <code>UPDATE</code> , <code>DELETE</code>) к конкретному <code>user_id</code> для обеспечения неотказуемости (невозможности отказа от действий). Текущее логирование без контекста пользователя недопустимо.	№3 (8.2/10)	ФСТЭК: УБИ.086 (Неотказуемость)
4	Безопасная обработка ошибок: Приложение должно перехватывать исключения и возвращать пользователю обобщенные сообщения об ошибках , не раскрывающие детали SQL-запросов, структуру БД или пути в файловой системе.	№5 (7.6/10)	CWE-209: Generation of Error Message Containing Sensitive Information
5	Валидация входных данных (Бизнес-логика): Приложение должно проверять типы и диапазоны данных (например, <code>price > 0</code> , <code>stock >= 0</code> , <code>quantity > 0</code>) на стороне сервера до выполнения запросов к	№10 (6.7/10)	OWASP ASVS: V5.1.1 (Input Validation)

	БД, чтобы предотвратить подмену данных (Tampering).		
6	Защита от SQL-инъекций (в динамических идентификаторах): Приложение должно использовать <i>только</i> безопасные методы экранирования ввода для динамических идентификаторов (таблиц/колонок), строго проверяя их по белому списку (allow list) перед формированием запроса <code>sql.Identifier</code> .	№7 (7.0/10)	OWASP ASVS: V5.3.3 / CWE-89
7	Устойчивость к DoS-атакам (Bulk Operations): Приложение должно ограничивать максимальное количество записей, обрабатываемых в одном <code>executemany()</code> запросе, и устанавливать таймауты на выполнение тяжелых операций.	№8 (6.6/10)	CWE-770: Allocation of Resources Without Limits (Throttling)
8	Аутентификация: защита от Brute-Force: Приложение должно реализовывать механизмы защиты от подбора пароля (brute-force), такие как задержка ответа, капча или блокировка учетной записи на время после нескольких неудачных попыток.	№6 (7.2/10)	OWASP ASVS: V2.1.7 (Anti-brute force)
9	Шифрование канала связи (TLS): Соединение между приложением и СУБД PostgreSQL должно устанавливаться с использованием шифрования (TLS/SSL) для предотвращения прослушивания трафика в сети.	№9 (6.6/10)	OWASP ASVS: V9.2.1 / CWE-319
10	Контроль целостности логов: Приложение должно логировать события на выделенный том (volume), и должен быть обеспечен контроль целостности логов (защита от их изменения или подчищения администратором хоста).	№4 (8.0/10)	ГОСТ Р 56939-2024 / Приказ ФСТЭК №117 (п.14.д)